



Security Assessment



Item 13 Internal Report

August 2026

Prepared for ether.fi



Disclaimer

This document is intended for **internal** use only.



Initial Commit Hash	Final Commit Hash
aa27177e	-

Protocol Scope

- src/top-up/TopUp.sol
- src/top-up/TopUpFactory.sol

Informational Issues

I-01. Permissionless `processTopUp` allows attackers to permanently grief the automated redirect flow for unsupported tokens

Description: The `TopUpFactory` exposes `processTopUp` and `processTopUpFromContracts` as permissionless external functions meant to sweep supported bridging tokens from users' `TopUp` contracts into the factory. However, these functions do not validate that the tokens passed in the `tokens` array are actually bridging-supported (i.e., they do not check `$.supportedTokens.contains(tokens[i])`).

This lack of validation allows anyone to call `processTopUp` with the address of an unsupported token that is intended for redirection (e.g., raw Backed xStocks). When called, the user's `TopUp` contract will blindly transfer these redirectable tokens into the `TopUpFactory`.

Once the tokens are maliciously swept into the `TopUpFactory`, the automated redirect flow is permanently broken for that user. When the backend attempts to call `batchRedirectToTradingSafe`, the `TopUp` contract will revert due to insufficient balance. Because the swept tokens are now commingled with other funds in the factory, the protocol administrators are forced to manually invoke `recoverFunds` to the `recoveryWallet` and perform off-chain forensics to trace the funds back to their rightful owners. This allows an attacker to cheaply and permanently DoS the system's automated recovery mechanism for all misrouted tokens.

Recommendation: Add validation in `TopUpFactory.processTopUp` and `processTopUpFromContracts` to ensure that only supported tokens can be swept. For example, add the following check inside the token processing loop (or before sweeping): `if (!$.supportedTokens.contains(tokens[i])) revert OnlySupportedTokens();`. Alternatively, perform this validation within `TopUp.processTopUp` by querying the factory's `isTokenSupported` mapping before executing the transfer.

Customer's response:

Fix review:

Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.